

bunq Internal Control

Data Retention and Secure Deletion

Document Control

Field	Value
Document ID	CTRL-DATA-004
Version	1.0
Owner	Data Protection Officer (DPO)
Approved By	Chief Compliance Officer / Chief Information Security Officer
Last Reviewed	2026-Q1
Classification	Internal — Restricted
Next Review Due	2027-Q1

1. Purpose

This procedure establishes bunq's data retention schedule, governing how long personal and operational data is kept, the legal basis for each retention period, and the process for secure and verifiable deletion once the retention period expires. Compliance with this control is necessary to satisfy GDPR Art. 5(1)(e) (storage limitation), GDPR Art. 17 (right to erasure), the Wwft record-keeping requirements, and AMLR Art. 56, while ensuring that data required for regulatory or legal purposes is not prematurely destroyed. The control also governs the handling of Data Subject Access Requests (DSARs) and the interaction between regulatory retention obligations and customer erasure rights.

2. Scope

In scope:

- All personal data processed by bunq B.V. and its licensed subsidiaries in the course of providing payment and banking services.
- Operational and system data that contains or can be linked to personal data (e.g., audit logs, system access logs, transaction records).
- Third-party processors acting on behalf of bunq, to the extent that bunq controls retention decisions under the data processing agreement.

Out of scope:

- Aggregated, fully anonymised data (no personal data component) — retained per business need without fixed schedule.
- Physical records (paper documents) — governed by Physical Records Policy SEC-007.
- Backup media retention — governed by IT Backup Policy ITOPS-012 (backup tapes are subject to the same maximum retention limits as live data but follow a separate disposal process).

3. Roles and Responsibilities

Role	Responsibility
Data Protection Officer (DPO)	Owns the retention schedule; advises on legal basis; reviews DSAR responses; escalates conflicts between retention obligations and erasure requests.
Chief Information Security Officer (CISO)	Ensures technical deletion mechanisms are in place and auditable; approves cryptographic erasure as a deletion method for encrypted data.
Compliance Officer (Data & Financial Crime)	Applies retention holds for records subject to regulatory obligations; coordinates with MLRO on Wwft-mandated records.
Engineering (Data Platform)	Implements automated purge jobs; maintains deletion audit trail in the data platform.
Customer Support / Privacy Team	Processes DSAR requests; coordinates with DPO on erasure responses.

4. Procedure

4.1 Retention Schedule

The following schedule is authoritative. The legal basis column identifies the primary retention driver. Where multiple bases apply, the longest mandatory period governs.

Data Category	Retention Period	Retention Basis	Start of Period
KYC / CDD documents (ID images, verification outcomes, UBO records)	5 years after account closure	Wwft Art. 33; AMLR Art. 56	Account closure date
Transaction records (payment instructions, settlement data, account statements)	7 years after transaction date	Wwft Art. 33; NL Tax Authority (*Belastingdienst*) 7-year bookkeeping requirement	Transaction date
Sanctions screening records (hit logs, alert dispositions, MLRO decisions)	5 years from decision date	AMLR Art. 56; Sanctiewet 1977	Decision/filing date
Suspicious Transaction Reports (STRs/UTRs) and internal suspicion reports	5 years from filing date	Wwft Art. 33	Date of report to FIU-NL
Audit logs (system access, data modification, privileged user actions)	10 years	ISO 27001 Annex A.12.4; internal audit requirements; potential litigation hold	Log creation date
Customer support and complaint records	5 years from case closure	Consumer protection; potential claims period	Case closure date
Marketing communications consent and preference records	Until consent is withdrawn, then deleted within 30 days	GDPR Art. 6(1)(a); ePrivacy Directive	Withdrawal date
App usage and behavioural analytics (linked to identity)	2 years from last activity	Legitimate interest (fraud prevention); reviewed at 2 years	Last activity date
Credit and risk model inputs (where personal data)	3 years from last use in model	GDPR Art. 22; legitimate interest	Last model use date
Employee data (payroll, HR records)	7 years after employment end	NL Burgerlijk Wetboek; tax law	Contract end date

Data Category	Retention Period	Retention Basis	Start of Period
DSAR request records (requests, responses, evidence of compliance)	3 years from response date	GDPR accountability (Art. 5(2))	Response date

4.2 Retention Holds

- Where data is subject to a legal hold (litigation, regulatory investigation, law enforcement request, or DNB supervisory inquiry), the DPO and Legal Director jointly issue a Retention Hold Notice that suspends automated purge for the specified data set until the hold is lifted.
- Retention holds are recorded in the data governance system with: hold ID, data scope, legal basis, issuing authority, date issued, and expected release date (if known).
- When a hold is lifted, the data falls back into the standard retention schedule; if the standard period has already expired, deletion is triggered within 30 days of the hold release.

4.3 Automated Purge Process

- The data platform executes automated purge jobs nightly for data in each category where the retention period has been met and no active hold applies.
- Before execution, the purge job queries the active holds register to exclude held records. This exclusion check is logged per job run.
- Purge jobs use one of the following deletion methods, depending on the storage system: - **Structured databases (PostgreSQL, RDS)**: Hard delete with referential integrity checks; a deletion event record (data category, row count, timestamp) is written to the immutable deletion audit log. - **Object storage (S3-equivalent)**: Object deletion with S3 versioning and MFA-delete enabled; deletion event written to audit log. - **Encrypted data at rest**: Where full-disk encryption is used and the data cannot be individually deleted without undue technical burden (e.g., archived cold storage), cryptographic key erasure (key deletion making data irrecoverable) is used as an equivalent to deletion. The CISO approves key erasure as the deletion method on a per-system basis.
- Engineering generates a monthly purge execution report showing: volumes purged per category, error rates, and any records held beyond their standard period with hold justification. The report is reviewed by the DPO and CISO within 5 business days.

4.4 Data Subject Access Requests (DSARs)

- Customers and other data subjects submit DSARs via the in-app privacy portal or by contacting support. All incoming DSARs are logged in the DSAR management system within 24 hours of receipt, with: requestor identity, request type (access, erasure, portability, rectification, restriction), and date received.
- Identity verification is required before any DSAR response is issued. For erasure or portability requests, identity must be verified at or above the standard KYC level for the relevant account type.
- Response deadline: 30 calendar days** from the verified receipt date, extendable by a further 60 days for complex or multiple requests, with notice to the data subject within the initial 30-day window. This deadline is tracked automatically in the DSAR management system with escalation alerts at day 20 and day 28.
- For erasure requests: the Privacy Team coordinates with the DPO to confirm which data categories are within scope for erasure (i.e., not subject to an overriding retention obligation). Data that must be retained under Wwft or AMLR is excluded from erasure and the customer is informed of the legal basis. Data not subject to a mandatory retention period is deleted within 30 days of the erasure request being confirmed.
- All DSAR outcomes (fulfilled, partially fulfilled, refused with reason) are documented in the DSAR management system.

4.5 Annual Retention Schedule Review

- 17. The DPO conducts an annual review of the retention schedule to incorporate: changes in applicable law or regulatory guidance; new data categories introduced by product changes (coordinated with the Privacy-by-Design review process); feedback from the monthly purge execution reports.
- 18. Material changes to retention periods require CCO approval and are communicated to the Management Board as part of the annual DPO report.

5. Frequency and Triggers

Activity	Frequency / Trigger
Automated purge job	Nightly
Purge execution report review	Monthly
DSAR response deadline	Within 30 calendar days of verified receipt
Retention hold review	At each quarterly Legal/Compliance review
Retention schedule review	Annually; and on material product/regulatory change

6. Records and Retention

This control is itself a retention record; the following applies to the records generated by executing this control:

- Deletion audit logs are retained for **10 years** (same period as audit logs generally) to enable regulatory confirmation that required records were held for the correct period and that expired records were deleted.
- DSAR request and response records are retained for **3 years** from response date (see schedule in 4.1).
- Retention hold notices and their lift records are retained for **10 years** from the hold lift date.
- Purge execution reports are retained for **7 years**.

7. References

Regulation	Relevance
GDPR Art. 5(1)(e)	Storage limitation principle
GDPR Art. 17	Right to erasure ("right to be forgotten")
GDPR Art. 5(2)	Accountability; documentation of compliance
Wwft 2018 (NL) Art. 33	5-year minimum retention for CDD and transaction records
EU Regulation 2024/1624 (AMLR) Art. 56	Record-keeping obligations for obliged entities
Belastingdienst / Burgerlijk Wetboek	7-year bookkeeping and tax record retention requirement
ISO/IEC 27001:2022 Annex A.8.10	Information deletion controls
EDPB Guidelines 01/2022 on Data Subject Rights	DSAR handling timelines and standards